

IT Incident Response Standard Operating Procedure

Operational workflow for information-security incident detection, containment and recovery

Document ID	MC-IT-004
Version	2.3
Effective Date	01 September 2026
Review Cycle	Annual
Classification	Internal — Confidential

1. Purpose

This SOP defines how MedCore identifies, reports, triages, contains, investigates, resolves and learns from information-security incidents.

2. Incident Scope

Examples include phishing, malware, ransomware indicators, unauthorized access, credential compromise, lost or stolen devices, data exposure, suspicious system activity, denial-of-service events and security-control failures.

3. Roles

Role	Responsibility
All users	Report suspected incidents promptly and preserve relevant information.
IT Service Desk	Receive tickets, perform initial categorization and route to Security.
IT Security / Incident Lead	Triage, contain, coordinate investigation and maintain incident record.
System Owner	Provide system context, approve operational actions and support recovery.
Legal & Compliance	Assess regulatory, contractual and notification considerations where relevant.
Communications / Management	Coordinate approved internal or external communications for material incidents.

4. Incident Lifecycle

1. Detection and reporting — identify the event and create an incident record.
2. Triage — determine affected systems, data, users, scope and initial severity.
3. Containment — limit further impact while preserving evidence.
4. Investigation — determine timeline, indicators, affected assets and likely cause.
5. Eradication — remove malicious artifacts or unauthorized access and correct exploited weaknesses.
6. Recovery — restore services safely, monitor for recurrence and confirm control operation.
7. Closure and lessons learned — document findings, actions, evidence and follow-up.

5. Severity Classification

Severity	Typical indicators	Target response
Critical	Major service disruption, widespread compromise, significant restricted-data exposure	Immediate incident command and senior escalation
High	Confirmed compromise, material business impact, sensitive system involvement	Prompt containment and management notification
Medium	Limited compromise or suspicious activity with contained impact	Timely investigation and remediation
Low	Minor security event or control issue with no material impact	Track, resolve and review for trends

6. Evidence Handling

Relevant logs, emails, endpoint artifacts, screenshots and other evidence should be preserved in approved locations. Investigators should document when evidence was collected and by whom where required.

Do not delete suspicious files or reset affected devices unless instructed by the incident lead or an approved recovery procedure.

7. Containment and Recovery Actions

Possible actions include disabling accounts, isolating endpoints, blocking indicators, restricting network paths, rotating credentials, suspending integrations and restoring known-good configurations.

Actions that could affect patient care or critical operations require coordination with the responsible system or clinical/operations owner.

8. Privacy and Regulatory Assessment

When an incident may involve personal, patient, financial or regulated information, Legal & Compliance and the relevant privacy owner should assess notification, contractual and evidence requirements.

Incident facts should be documented carefully; legal or regulatory conclusions should be made by the authorized responsible functions.

9. Communication

Only authorized personnel may communicate externally about a material security incident. Internal communications should provide actionable information without unnecessarily distributing sensitive incident details.

Users should not post incident information to public forums or personal social-media accounts.

10. Post-Incident Review

Material incidents should receive a documented review covering root cause or contributing factors, control gaps, response effectiveness and corrective actions.

Actions should have accountable owners and target dates. Repeated incidents should inform security awareness, architecture or control improvements.